

NETWORK TRAFFIC ANALYSIS

Sample: wireshark-sample01.pcap

Scenario: Initial triage suggests that the internal host may have downloaded a suspicious executable that imitates the name of a legitimate Windows process. You must use Wireshark to identify the suspicious communication, extract relevant indicators, and decide whether the activity is benign, suspicious, or malicious.

Provide answer / evidence for each of the following questions:

Establish Capture Scope: Before investigating content, analysts need to understand the size, duration, and scope of the evidence.

Questions:

- What is the total number of packets in the capture?
- What is the start time and end time of the capture?
- What is the duration of the capture?
- Why is it useful to understand the time window before analyzing suspicious activity?

Identify Active Hosts

Review the internal and external IP addresses.

Questions:

- Which internal IP address appears to be the main endpoint in this capture?
- Which external IP addresses communicate with this internal host?
- Based on the endpoint statistics, which internal host should be investigated further?

Identify Important Conversations

Review the IPv4 and TCP tabs.

Questions:

- Which TCP conversations involve the internal host?
- Which external IP addresses communicate with the internal host over TCP?
- Are any conversations using port 80?
- Which conversation appears most relevant for further investigation? Provide evidence?

Review Protocols Present in the PCAP

Questions:

- Which major protocols are present?
- Why is visible HTTP traffic useful in an investigation?
- Does the presence of HTTP allow you to inspect URLs, paths, headers, and possibly downloaded files?

Inspect HTTP Requests

Apply appropriate filter to review the HTTP request list.

Answer:

- What HTTP GET and POST requests are visible?
- Which internal host generated these HTTP requests?
- Which external servers received them?
- Do any request paths look unusual?
- Do any requests appear to involve downloading a file?
- Are any requested files executable or suspicious?

Identify Any Suspicious File Download: From the HTTP request list, look for file downloads, especially files with extensions such as: .exe, .dll, .zip, .scr, .bat, .ps1, .docm, .xlsm

Questions:

- Is there any executable file requested over HTTP?
- What is the filename?
- What is the request path?
- Which external IP address hosted the file?
- What is the full URL?
- Was the file downloaded from a trusted or expected domain?

Inspect the HTTP Stream:

Questions:

- What HTTP method was used?
- What Host value is shown?
- What file path was requested?
- What User-Agent value was used?
- What response did the server return?
- Does the stream indicate that the executable was delivered to the client?

Determine Why the Download Is Suspicious

Question:

- Why is the filename .audiodg.exe suspicious?
- What legitimate Windows process name does it resemble?
- Why is it suspicious that the file was downloaded from an IP-based HTTP URL instead of an official Microsoft domain?
- Would a legitimate Windows component normally be downloaded from this location?
- How does this affect your classification of the activity?

Look for Post-Download Activity

After identifying the suspicious download, continue reviewing HTTP requests after the download time.

Questions:

- Are there HTTP POST requests after the suspicious download?
- Which external IP receives these POST requests?
- What User-Agent is associated with the POST traffic?
- Does the User-Agent look like a normal modern browser?

- Why might HTTP POST activity after a suspicious executable download be concerning?

Validate Using Reputation Sources: Use approved external reputation tools such as VirusTotal, WHOIS, or DomainTools to investigate IOCs that were discovered.

Questions:

- What is the reputation of the suspicious URL?
- What is the reputation of the external IP hosting the executable?
- What is the reputation or context of the second external IP?
- Is the User-Agent associated with suspicious or malware-related activity?
- Do the reputation results support the network evidence?

Sample: wireshark-sample02.pcap

Establish the Capture Scope

Open the PCAP in Wireshark.

Answer the following:

- What is the total number of packets in the capture?
- What is the capture start time and end time?
- How long does the capture last?
- Based on the duration and packet count, is this a small focused capture or a longer endpoint activity capture?

Identify the Main Internal Host

Answer the following:

- Which internal IP address appears most active in the capture?
- Which other internal IP address appears to function as an infrastructure server, such as DNS or domain controller?
- Which internal host should be treated as the primary system of interest?

Identify Important Conversations

Answer the following:

- Which external IP addresses have significant communication with 10.0.0.149?
- Which conversations use TCP port 80?
- Which conversation appears most relevant for cleartext investigation?
- Why is traffic on port 80 especially useful compared with traffic on port 443?

Review Visible HTTP Requests

Apply display filter to Review the HTTP request list.

Answer the following:

- Which internal host generated the suspicious HTTP request?
- Which external IP address received the request?
- What HTTP method was used?
- What request URI was requested?
- What User-Agent was used?

- Does the User-Agent look like normal browser traffic or command-line/tool-based traffic?

Investigation Step 5: Inspect the HTTP Stream

Answer the following:

- What is the full HTTP request?
- What is the Host value?
- What server response code is returned?
- What Content-Type is returned by the server?
- What Content-Length is shown?
- Does the response suggest that a file was successfully delivered?

Determine Whether the Downloaded Object Is Suspicious

Answer the following:

- What file or object is available for export?
- What is the object name or URI?
- What is the source IP address?
- What is the content type?
- Does the object appear to be a normal document, image, certificate, or executable-like binary?
- Why is a .dat file served as application/octet-stream suspicious in this context?
- What additional analysis would you perform on the exported object in a safe malware-analysis environment?

Identify Victim Host Details

Answer the following:

- What hostname is associated with 10.0.0.149?
- What internal domain name appears in the capture?
- Is there evidence of a Windows domain environment?
- Can you identify a likely Windows user account associated with the activity?

Look for Post-Download Internal Reconnaissance or Lateral Movement

After identifying the suspicious download, continue investigating later traffic from 10.0.0.149.

Answer the following:

- Does 10.0.0.149 generate many ARP requests for other internal IP addresses?
- Does this pattern resemble normal occasional ARP resolution or scanning/reconnaissance?
- Does 10.0.0.149 communicate with 10.0.0.6 over SMB?
- Why is SMB communication with a domain controller important in a malware investigation?
- Does the later internal activity increase concern that the infection may have attempted discovery or lateral movement?

Validate with Reputation and Threat Intelligence

Use approved reputation or threat-intelligence sources to investigate IOCs discovered in your investigation.

Answer the following:

- Is the external IP associated with suspicious or malicious activity?
- Is the downloaded file hash known to security vendors?
- What malware family is associated with the file or traffic?
- Do the reputation results support your Wireshark findings?

Sample: wireshark_challenge.pcap

Your organization received an alert indicating unusual traffic patterns and a large number of repeated queries originating from one of its external-facing endpoints (172.16.1.16). Analyze the **wireshark_challenge.pcap** packet capture and answer the following questions:

1. How many HTTP packets are contained in the capture file?
2. What relative path victim accessed on the web server to request a file download?
3. Based on the response header, what file type or format the downloaded file is?
4. What is the actual file signature (magic bytes) contained in the downloaded file?
5. What command-line utility or program did the victim use to download the file?
6. What is the SHA-256 hash of the downloaded file?
7. Submit the uncovered hash to VirusTotal. Based on the popular threat label and tags, what type of malware infected the endpoint?
8. Review the domain names queried within the capture. In defanged format, what is the base domain name that is repeatedly queried?
9. Read about MITRE ATT&CK ID T1071.004. What is the commonly used name for the attack technique likely observed in this PCAP file?